

Auditoría de cumplimiento integral — Kryon

Cliente: Banco Demo Paraguay S.A. · Host: pve01.bancodemo.com.py · Fecha / Date: 2026-04-20 14:58 · Alcance: PCI-DSS + Proxmox VE + Active Directory

Riesgo agregado / Overall risk: **CRÍTICO**

Hash reproducibilidad / Reproducibility hash:
e6af4964f51dab1f770203f4b3716974506fc82b5430d424f7552279399a3ed8

Separación de responsabilidades / Separation of duties: los veredictos (PASS/FAIL/N/A/ERROR) y la evidencia (comando ejecutado + output raw) provienen de motores determinísticos reproducibles. Las secciones marcadas **LLM NARRATIVA** son prosa explicativa generada por modelo de lenguaje y no modifican los veredictos ni la evidencia. Para defensibilidad regulatoria, el auditor debe basarse en la evidencia determinística.

Resumen ejecutivo

Se ejecutaron **22** controles sobre el host. Resultados: **12 FAIL**, **9 PASS**, 0 N/A, 1 ERROR. Nivel de riesgo agregado: **CRÍTICO**.

EN Executive summary. 22 controls executed on the host. Results: **12 FAIL**, **9 PASS**, 0 N/A, 1 ERROR. Overall risk: **CRÍTICO**. Framework: Kryon Full Compliance Audit. Scope: PCI-DSS + Proxmox VE + Active Directory.

Control	Título	Sección	Veredicto	Severidad
2.2.7	SSH non-console admin encryption (key-only, no root)	2	FAIL	CRITICAL
AD-2.1	No kerberoastable accounts with weak/stale passwords	2	FAIL	CRITICAL
AD-2.2	krbtgt password rotated within last 180 days	2	FAIL	CRITICAL
PVE-2.1	SSH allows only key-based, non-root authentication	2	FAIL	CRITICAL
PVE-3.1	Multi-factor auth enforced for privileged Proxmox users	3	FAIL	CRITICAL
AD-1.1	LDAP signing enforced (rejects unsigned binds on 389/tcp)	1	FAIL	HIGH
PVE-1.1	Web UI SSL certificate is CA-signed and not expired	1	FAIL	HIGH
AD-3.1		3	FAIL	HIGH

Control	Título	Sección	Veredicto	Severidad
	Domain Admins group has <= 5 active members			
PVE-3.2	Proxmox API tokens follow least-privilege + expiry	3	FAIL	HIGH
6.3.3	Security patches applied within 30 days	6	FAIL	HIGH
PVE-5.1	Proxmox version is supported and security patches applied	5	FAIL	MEDIUM
6.4.1	Public web app protection headers (HSTS/CSP/XFO/XCTO)	6	FAIL	MEDIUM
AD-5.1	Critical AD audit events logged and forwarded to SIEM	5	ERROR	HIGH
PVE-1.2	Privileged API endpoints require authentication	1	PASS	CRITICAL
AD-4.1	SMB signing required on 445/tcp (mitigates NTLM relay)	4	PASS	CRITICAL
AD-1.2	LDAPS (636/tcp) available with valid CA-signed cert	1	PASS	HIGH
AD-1.3	Anonymous LDAP bind is rejected (no enumeration)	1	PASS	HIGH
10.2.1	Audit trails active for privileged actions	10	PASS	HIGH
2.2.2	Vendor default accounts disabled or secured	2	PASS	HIGH
AD-3.2	Domain password policy meets banking minimums (>=12 / complex / lockout)	3	PASS	HIGH
PVE-4.1	Datacenter firewall enabled with default-deny ingress	4	PASS	HIGH
8.3.6	Minimum password complexity (>=12, mixed classes)	8	PASS	HIGH

Hallazgos / Findings

PCI 2.2.7 — SSH non-console admin encryption (key-only, no root)

FAIL

Sección 2 · Severidad CRITICAL · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `sshd -T | grep -E 'permitrootlogin|passwordauthentication'`

Hallazgos estructurados:

```
{
  "PermitRootLogin": "yes",
  "PasswordAuthentication": "yes",
  "issues": [
    "PermitRootLogin=yes (should be no)",
    "PasswordAuthentication=yes (should be no)"
  ]
}
```

Remediación determinística (texto de la regla)

Edit /etc/ssh/sshd_config: PermitRootLogin no, PasswordAuthentication no. Validate sudo+key auth works for a non-root admin account BEFORE restarting sshd.

PCI AD-2.1 — No kerberoastable accounts with weak/stale passwords

FAIL

Sección 2 · Severidad CRITICAL · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `ldapsearch -x '...(servicePrincipalName=*)...' sAMAccountName`

Hallazgos estructurados:

```
{
  "kerberoastable_count": 3,
  "accounts": [
    "svc_backup",
    "svc_oracle",
    "svc_temenos"
  ],
  "issues": [
    "3 active user account(s) with SPN (kerberoastable)"
  ]
}
```

Remediación determinística (texto de la regla)

Rotate each SPN-holder account password to ≥ 25 random chars. Best path: migrate to Group Managed Service Accounts (gMSA): `New-ADServiceAccount -Name svc_oracle -DNSHostName oracle.bank.local` gMSAs auto-rotate every 30 days — kerberoasting yields nothing useful.

PCI AD-2.2 — krbtgt password rotated within last 180 days

FAIL

Sección 2 · Severidad CRITICAL · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `ldapsearch '(sAMAccountName=krbtgt)' pwdLastSet msDS-KeyVersionNumber`

Hallazgos estructurados:

```
{
  "last_changed_utc": "2024-02-10T09:15:32+00:00",
  "age_days": 423,
  "kvn": "2",
  "issues": [
    "krbtgt password is 423 days old (>180)"
  ]
}
```

Remediación determinística (texto de la regla)

Download Microsoft New-KrbtgtKeys.ps1. Run it TWICE with 10h between runs to invalidate cached tickets. Schedule semiannual. This is critical: a leaked krbtgt hash = Golden Ticket forever.

Contexto (LLM)

LLM NARRATIVA La cuenta krbtgt — que firma todos los tickets Kerberos del dominio — tiene su contraseña sin rotar hace 423 días. Si un atacante obtiene el hash de krbtgt (por compromiso previo, copias de NTDS, o dump de memoria en un DC), puede forjar 'Golden Tickets' con validez de 10 años que le dan acceso persistente indetectable por los logs normales.

Detalle de remediación (LLM)

LLM NARRATIVA Microsoft publica el script New-KrbtgtKeys.ps1 para rotación segura. Debe ejecutarse DOS veces con 10 horas entre corridas, para invalidar los tickets emitidos previamente. Esta rotación es una operación rutinaria en entornos bancarios y debe agendarse semestralmente como política.

PCI PVE-2.1 — SSH allows only key-based, non-root authentication

FAIL

Sección 2 · Severidad CRITICAL · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `sshd -T | grep -E 'permitrootlogin|passwordauth'`

Hallazgos estructurados:

```
{
  "PermitRootLogin": "yes",
  "PasswordAuthentication": "yes",
  "issues": [
    "PermitRootLogin=yes (should be no)",
    "PasswordAuthentication=yes (should be no)"
  ]
}
```

Remediación determinística (texto de la regla)

See PCI-DSS 2.2.7 — identical SSH hardening steps.

Contexto (LLM)

LLM NARRATIVA El servidor Proxmox permite iniciar sesión SSH directamente como root con contraseña. En términos bancarios, esto significa que un atacante con acceso a la red de administración solo necesita adivinar una contraseña para tomar control total del hipervisor. Toda la infraestructura virtualizada (core-banking, AD, bases de datos) corre sobre este hipervisor.

Detalle de remediación (LLM)

LLM NARRATIVA Se recomienda deshabilitar el login directo de root y forzar autenticación por llave SSH. Previamente, validar que existe una cuenta de administrador con sudo y llave funcional. El cambio requiere una ventana de mantenimiento de 15 minutos y es reversible desde la consola física.

PCI PVE-3.1 — Multi-factor auth enforced for privileged Proxmox users

FAIL

Sección 3 · Severidad CRITICAL · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: cat /etc/pve/domains.cfg ; cat /etc/pve/user.cfg

Hallazgos estructurados:

```
{
  "realm_tfa": {
    "pam": false,
    "pve": false
  },
  "admin_users_no_tfa": [
    "root@pam",
    "admin@pam",
    "ops@pve"
  ],
  "issues": [
    "realm 'pam' has no default-tfa",
    "realm 'pve' has no default-tfa",
    "3 privileged users without TFA: root@pam, admin@pam, ops@pve",
    "root@pam has no TFA binding"
  ]
}
```

Remediación determinística (texto de la regla)

Web UI → Datacenter → Realm → edit 'pam' → Default TFA: TOTP. Then per-user: enroll each admin via Web UI → Username → TFA. Enforce root@pam first. Banking regulatory: SIB Resolución 06/2020 art.15.

Contexto (LLM)

LLM NARRATIVA Tres cuentas administrativas del hipervisor (incluida root) no tienen configurado segundo factor de autenticación. En el marco regulatorio de la SIB (Resolución 06/2020 art.15) y PCI-DSS 8.4, el MFA para accesos privilegiados no es opcional: es requisito auditable.

Detalle de remediación (LLM)

LLM NARRATIVA Activar TFA por realm (PAM y PVE) como default. Enrolar cada administrador individualmente via el panel web. Priorizar root@pam antes que los demás. Mantener un token de respaldo guardado en bóveda física para contingencia.

PCI AD-1.1 — LDAP signing enforced (rejects unsigned binds on 389/tcp)

FAIL

Sección 1 · Severidad HIGH · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: ldapsearch -x -H ldap://dc01:389 -D 'auditor@BANK.LOCAL' -w ***
-b '' -s base namingContexts

Hallazgos estructurados:

```
{
  "simple_bind": "succeeded",
  "issues": [
    "Simple bind on 389 succeeded – LDAP signing NOT enforced"
  ]
}
```

Remediación determinística (texto de la regla)

GPO → Domain Controller Policy → 'Domain controller: LDAP server signing requirements' = Require signing. Registry: NTDS\Parameters\LDAPServerIntegrity=2. Audit legacy apps first — unsigned clients break.

PCI PVE-1.1 — Web UI SSL certificate is CA-signed and not expired

FAIL

Sección 1 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: openssl x509 -in /etc/pve/local/pve-ssl.pem -subject -issuer
Hallazgos estructurados:

```
{
  "subject": "CN=pve01.bancodemo.com.py",
  "issuer": "CN=pve01.bancodemo.com.py",
  "self_signed": true,
  "days_to_expiry": 211,
  "issues": [
    "Certificate is self-signed (subject == issuer)"
  ]
}
```

Remediación determinística (texto de la regla)

Replace with CA-signed cert. Via Web UI → Datacenter → Certificates → Upload Custom. CLI: `pvenode cert set --force <cert.pem> <key.pem>`. Use RSA >= 2048 or ECDSA P-256.

PCI AD-3.1 — Domain Admins group has <= 5 active members

FAIL

Sección 3 · Severidad HIGH · Host dc01.bancomdemo.com.py

Evidencia determinística

Comando ejecutado: `ldapsearch -b 'CN=Domain Admins,CN=Users,DC=BANK,DC=LOCAL' member`

Hallazgos estructurados:

```
{
  "member_count": 18,
  "threshold": 5,
  "members_sample": [
    "CN=Administrator",
    "CN=John Doe (IT Infra)",
    "CN=Jane Roe (retired 2023)",
    "CN=svc_deployment",
    "CN=Support Console 1",
    "CN=Support Console 2",
    "CN=Maria Lopez (contractor)",
    "CN=ADMIN_TEMP_Q1"
  ],
  "issues": [
    "Domain Admins has 18 members (threshold 5)"
  ]
}
```

Remediación determinística (texto de la regla)

Remove stale members (retired employees, legacy temp accounts, ended contractors).
Implement JIT admin: PAM solution or Microsoft AAM. Target: <=5 permanent DAs. Audit DA monthly.

Contexto (LLM)

LLM NARRATIVA El grupo 'Domain Admins' contiene 18 miembros, incluyendo cuentas de ex-empleados y contratistas cuyo engagement ya terminó. Cada miembro es equivalente a root en todo el dominio: comprometer una sola de esas cuentas equivale a comprometer toda la infraestructura Windows del banco.

Detalle de remediación (LLM)

LLM NARRATIVA Revisar la lista completa con el equipo de RR.HH. y remover inmediatamente cualquier cuenta de persona que ya no trabaja en el banco. Para los administradores vigentes, migrar a un modelo Just-In-Time (PAM): los privilegios se conceden por tiempo limitado, solo cuando el admin los solicita y quedan auditados. Meta operativa: máximo 5 DAs permanentes.

PCI PVE-3.2 — Proxmox API tokens follow least-privilege + expiry

FAIL

Sección 3 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `stat -c '%a %U %G' /etc/pve/priv/token.cfg ; cat /etc/pve/priv/token.cfg`

Hallazgos estructurados:

```
{
  "mode": "644",
  "tokens_total": 2,
  "tokens_no_expiry": 2,
  "tokens_root_pam": 2,
  "tokens_privsep_off": 2,
  "issues": [
    "token.cfg world-permissions != 0 (mode 644)",
    "2 token(s) with no expiry",
    "2 token(s) bound to root@pam",
    "2 token(s) with privsep=0 (inherits full perms)"
  ]
}
```

Remediación determinística (texto de la regla)

`chmod 640 root:www-data /etc/pve/priv/token.cfg. Migrate automation to a dedicated non-root user: pveum user add ci@pve --password $(pwgen -s 32 1) pveum user token add ci@pve ops --privsep 1 --expire $(date -d '+1 year' +%s) Rotate tokens yearly.`

PCI 6.3.3 — Security patches applied within 30 days

FAIL

Sección 6 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `apt-get -s upgrade | grep -c '^Inst '`

Hallazgos estructurados:

```
{
  "pending_security_updates": 15,
  "oldest_pending_days": 47
}
```

Remediación determinística (texto de la regla)

Run ``apt update && apt dist-upgrade`` on a maintenance window. Subscribe to Debian security announcements and apply within 30 days per PCI-DSS 6.3.3.

PCI PVE-5.1 — Proxmox version is supported and security patches applied **FAIL**

Sección 5 · Severidad MEDIUM · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: pveversion --verbose ; apt-get -s upgrade | grep -c '^Inst '
Hallazgos estructurados:

```
{
  "version": "8.1.4",
  "pending_upgrades": 42,
  "issues": [
    "42 package upgrades pending"
  ]
}
```

Remediación determinística (texto de la regla)

Run `apt update && apt dist-upgrade -y` on maintenance window. Use pve-enterprise repo in prod (requires subscription).

PCI 6.4.1 — Public web app protection headers (HSTS/CSP/XFO/XCTO) **FAIL**

Sección 6 · Severidad MEDIUM · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: curl -skI https://banca.bancodemo.com.py/ | head -15
Hallazgos estructurados:

```
{
  "HSTS": null,
  "CSP": null,
  "X-Frame-Options": null,
  "X-Content-Type-Options": null,
  "missing": [
    "Strict-Transport-Security",
    "Content-Security-Policy",
    "X-Frame-Options",
    "X-Content-Type-Options"
  ]
}
```

Remediación determinística (texto de la regla)

Add in nginx server block: add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always; add_header Content-Security-Policy "default-src 'self'" always; add_header X-Frame-Options DENY always; add_header X-Content-Type-Options nosniff always;

PCI AD-5.1 — Critical AD audit events logged and forwarded to SIEM

ERROR

Sección 5 · Severidad HIGH · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: nmap -Pn -p 5985,5986 dc01 ; rpcclient -U ... -c srvinfo dc01
Hallazgos estructurados:

```
{
  "winrm_listening": false,
  "rpc_reachable": false,
  "note": "Event forwarding presence could not be verified remotely – requires on-DC script.",
  "issues": [
    "WinRM (5985/5986) not reachable – Event Forwarding to SIEM unlikely"
  ]
}
```

Remediación determinística (texto de la regla)

Enable Windows Event Collector + WEF subscription. Advanced Audit Policy Configuration → enable Logon, Kerberos, DS Access, Account Management (all Success+Failure). Forward to Splunk/Wazuh via WEF.

PCI PVE-1.2 — Privileged API endpoints require authentication

PASS

Sección 1 · Severidad CRITICAL · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: curl -sk -o /dev/null -w '%{http_code}' https://127.0.0.1:8006/api2/json/nodes

Hallazgos estructurados:

```
{
  "endpoints": {
    "/api2/json/version": "200",
    "/api2/json/nodes": "401",
    "/api2/json/cluster/status": "401",
    "/api2/json/access/users": "401"
  }
}
```

Remediación determinística (texto de la regla)

Already compliant — privileged endpoints require auth. Keep monitoring.

PCI AD-4.1 — SMB signing required on 445/tcp (mitigates NTLM relay)

PASS

Sección 4 · Severidad CRITICAL · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: nmap -Pn -p 445 --script smb2-security-mode dc01

Hallazgos estructurados:

```
{  
  "message_signing": "required"  
}
```

Remediación determinística (texto de la regla)

Already compliant. Also enable on member servers.

PCI AD-1.2 — LDAPS (636/tcp) available with valid CA-signed cert

PASS

Sección 1 · Severidad HIGH · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: echo | openssl s_client -connect dc01:636 -servername dc01 -showcerts

Hallazgos estructurados:

```
{  
  "subject": "CN=dc01.bancodemo.com.py",  
  "issuer": "CN=BANK-CORP-CA",  
  "days_to_expiry": 312  
}
```

Remediación determinística (texto de la regla)

Already compliant. Keep auto-enrollment via GPO in place.

PCI AD-1.3 — Anonymous LDAP bind is rejected (no enumeration)

PASS

Sección 1 · Severidad HIGH · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: ldapsearch -x -H ldap://dc01:389 -b '' -s base

Hallazgos estructurados:

```
{  
  "anonymous_bind_accepted": false  
}
```

Remediación determinística (texto de la regla)

Already compliant. Maintain dsHeuristics setting in config.

PCI 10.2.1 — Audit trails active for privileged actions

PASS

Sección 10 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: systemctl is-active auditd ; ls /etc/audit/rules.d/

Hallazgos estructurados:

```
{  
  "auditd_active": true,  
  "pci_rules_loaded": true  
}
```

Remediación determinística (texto de la regla)

Already compliant — verify forwarding to SIEM is also configured (not in scope of this check).

PCI 2.2.2 — Vendor default accounts disabled or secured

PASS

Sección 2 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `getent shadow | awk -F: '$2 == "" || $2 == "*" ; mysql -e 'SELECT User FROM mysql.user WHERE authentication_string=""'`

Hallazgos estructurados:

```
{
  "empty_shadow_entries": 0,
  "default_mysql_accounts": 0
}
```

Remediación determinística (texto de la regla)

Maintain policy: disable every vendor-default account at provisioning time; rotate root DB passwords on install.

PCI AD-3.2 — Domain password policy meets banking minimums (≥ 12 / complex / lockout)

PASS

Sección 3 · Severidad HIGH · Host dc01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: `ldapsearch -b 'DC=BANK,DC=LOCAL' -s base minPwdLength pwdProperties pwdHistoryLength lockoutThreshold`

Hallazgos estructurados:

```
{
  "minPwdLength": 12,
  "pwdProperties": 1,
  "pwdHistoryLength": 24,
  "lockoutThreshold": 10,
  "maxPwdAge_days": 90
}
```

Remediación determinística (texto de la regla)

Already compliant with banking baseline. Review at annual policy cycle.

PCI PVE-4.1 — Datacenter firewall enabled with default-deny ingress

PASS

Sección 4 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: pve-firewall status ; cat /etc/pve/firewall/cluster.fw
Hallazgos estructurados:

```
{
  "status": "enabled/running",
  "enable": "1",
  "policy_in": "DROP"
}
```

Remediación determinística (texto de la regla)

Already compliant. Review per-VM rulesets quarterly.

PCI 8.3.6 — Minimum password complexity (≥ 12 , mixed classes)

PASS

Sección 8 · Severidad HIGH · Host pve01.bancodemo.com.py

Evidencia determinística

Comando ejecutado: grep -E 'minlen|minclass' /etc/security/pwquality.conf
Hallazgos estructurados:

```
{
  "minlen": 12,
  "minclass": 3
}
```

Remediación determinística (texto de la regla)

Already compliant — keep pwquality.conf under config management.

Apéndice A — Evidencia cruda / Appendix A — Raw evidence

Comandos ejecutados y output stdout/stderr sin procesar. Permite reproducir manualmente cada hallazgo / Commands executed and raw stdout/stderr, enabling manual reproduction of every finding.

PCI 2.2.7 — SSH non-console admin encryption (key-only, no root)

Comando

```
sshd -T | grep -E 'permitrootlogin|passwordauthentication'
```

stdout (raw)

```
permitrootlogin yes
passwordauthentication yes
```

stderr (raw)

```
(vacío)
```

PCI AD-2.1 — No kerberoastable accounts with weak/stale passwords

Comando

```
ldapsearch -x '...(servicePrincipalName=*)...' sAMAccountName
```

stdout (raw)

```
dn: CN=svc_oracle,...
sAMAccountName: svc_oracle

dn: CN=svc_backup,...
sAMAccountName: svc_backup

dn: CN=svc_temenos,...
sAMAccountName: svc_temenos
```

stderr (raw)

```
(vacío)
```

PCI AD-2.2 — krbtgt password rotated within last 180 days

Comando

```
ldapsearch '(sAMAccountName=krbtgt)' pwdLastSet msDS-KeyVersionNumber
```

stdout (raw)

```
pwdLastSet: 132876543210000000
msDS-KeyVersionNumber: 2
```

stderr (raw)

```
(vacío)
```

PCI PVE-2.1 — SSH allows only key-based, non-root authentication

Comando

```
sshd -T | grep -E 'permitrootlogin|passwordauth'
```

stdout (raw)

```
permitrootlogin yes
passwordauthentication yes
```

stderr (raw)


```
(vacío)
```

PCI PVE-3.1 — Multi-factor auth enforced for privileged Proxmox users

Comando

```
cat /etc/pve/domains.cfg ; cat /etc/pve/user.cfg
```

stdout (raw)

```
pam: pam  
  
pve: pve  
  
user:root@pam:1:....:  
user:admin@pam:1:....:  
user:ops@pve:1:....:
```

stderr (raw)

```
(vacío)
```

PCI AD-1.1 — LDAP signing enforced (rejects unsigned binds on 389/tcp)

Comando

```
ldapsearch -x -H ldap://dc01:389 -D 'auditor@BANK.LOCAL' -w *** -b '' -s base namingContexts
```

stdout (raw)

```
result: 0 Success  
namingContexts: DC=BANK,DC=LOCAL
```

stderr (raw)

```
(vacío)
```

PCI PVE-1.1 — Web UI SSL certificate is CA-signed and not expired

Comando

```
openssl x509 -in /etc/pve/local/pve-ssl.pem -subject -issuer
```

stdout (raw)

```
subject=CN=pve01.bancodemo.com.py  
issuer=CN=pve01.bancodemo.com.py
```

stderr (raw)

```
(vacío)
```

PCI AD-3.1 — Domain Admins group has <= 5 active members

Comando

```
ldapsearch -b 'CN=Domain Admins,CN=Users,DC=BANK,DC=LOCAL' member
```

stdout (raw)

```
(18 members – truncated)
```

stderr (raw)

```
(vacío)
```

PCI PVE-3.2 — Proxmox API tokens follow least-privilege + expiry

Comando

```
stat -c '%a %U %G' /etc/pve/priv/token.cfg ; cat /etc/pve/priv/token.cfg
```

stdout (raw)

```
644 root www-data
root@pam!backup:0:0:automated nightly backups:
root@pam!monitoring:0:0:zabbix integration:
```

stderr (raw)

```
(vacío)
```

PCI 6.3.3 — Security patches applied within 30 days

Comando

```
apt-get -s upgrade | grep -c '^Inst '
```

stdout (raw)

```
15
```

stderr (raw)

```
(vacío)
```

PCI PVE-5.1 — Proxmox version is supported and security patches applied

Comando

```
pveversion --verbose ; apt-get -s upgrade | grep -c '^Inst '
```

stdout (raw)

```
pve-manager/8.1.4/ec5affc9e41f1d79
42
```

stderr (raw)

```
(vacío)
```

PCI 6.4.1 — Public web app protection headers (HSTS/CSP/XFO/XCTO)

Comando

```
curl -skI https://banca.bancodemo.com.py/ | head -15
```

stdout (raw)

```
HTTP/2 200  
server: nginx/1.18.0  
content-type: text/html
```

stderr (raw)

```
(vacío)
```

PCI AD-5.1 — Critical AD audit events logged and forwarded to SIEM

Comando

```
nmap -Pn -p 5985,5986 dc01 ; rpcclient -U ... -c srvinfo dc01
```

stdout (raw)

```
5985/tcp filtered http  
5986/tcp filtered https  
rpcclient: NT_STATUS_IO_TIMEOUT
```

stderr (raw)

```
(vacío)
```

PCI PVE-1.2 — Privileged API endpoints require authentication

Comando

```
curl -sk -o /dev/null -w '%{http_code}' https://127.0.0.1:8006/api2/json/nodes
```

stdout (raw)

```
401
```

stderr (raw)

```
(vacío)
```

PCI AD-4.1 — SMB signing required on 445/tcp (mitigates NTLM relay)

Comando

```
nmap -Pn -p 445 --script smb2-security-mode dc01
```

stdout (raw)

```
Message signing: required
```

stderr (raw)

```
(vacío)
```

PCI AD-1.2 — LDAPS (636/tcp) available with valid CA-signed cert**Comando**

```
echo | openssl s_client -connect dc01:636 -servername dc01 -showcerts
```

stdout (raw)

```
subject=CN=dc01.bancodemo.com.py  
issuer=CN=BANK-CORP-CA
```

stderr (raw)

```
(vacío)
```

PCI AD-1.3 — Anonymous LDAP bind is rejected (no enumeration)**Comando**

```
ldapsearch -x -H ldap://dc01:389 -b '' -s base
```

stdout (raw)

```
result: 1 Operations error  
000004DC: LdapErr: anonymous bind disallowed
```

stderr (raw)

```
(vacío)
```

PCI 10.2.1 — Audit trails active for privileged actions**Comando**

```
systemctl is-active auditd ; ls /etc/audit/rules.d/
```

stdout (raw)

```
active  
00-base.rules 30-pci-dss-v31.rules 99-finalize.rules
```

stderr (raw)

```
(vacío)
```

PCI 2.2.2 — Vendor default accounts disabled or secured

Comando

```
getent shadow | awk -F: '$2 == "" || $2 == "*" ' ; mysql -e 'SELECT User FROM mysql.user WHERE authentication_string=""'
```

stdout (raw)

```
(no empty-password accounts found)
(mysql: no default creds)
```

stderr (raw)

```
(vacío)
```

PCI AD-3.2 — Domain password policy meets banking minimums (≥ 12 / complex / lockout)

Comando

```
ldapsearch -b 'DC=BANK,DC=LOCAL' -s base minPwLength pwdProperties pwdHistoryLength lockoutThreshold
```

stdout (raw)

```
minPwLength: 12
pwdProperties: 1
pwdHistoryLength: 24
lockoutThreshold: 10
```

stderr (raw)

```
(vacío)
```

PCI PVE-4.1 — Datacenter firewall enabled with default-deny ingress

Comando

```
pve-firewall status ; cat /etc/pve/firewall/cluster.fw
```

stdout (raw)

```
Status: enabled/running
enable: 1
policy_in: DROP
```

stderr (raw)

```
(vacío)
```

PCI 8.3.6 — Minimum password complexity (≥ 12 , mixed classes)

Comando

```
grep -E 'minlen|minclass' /etc/security/pwquality.conf
```

stdout (raw)

```
minlen = 12  
minclass = 3
```

stderr (raw)

```
(vacío)
```

Este reporte se considera válido únicamente acompañado del artifact JSON cuyo SHA-256 coincide con e6af4964f51dab1f770203f4b3716974... Cualquier modificación del JSON invalida este reporte. Generado por Kryon compliance engine.

This report is valid only alongside the JSON artifact whose SHA-256 matches the hash above. Any modification to the JSON invalidates this report.